CANONICAL SECURITY MATRIX — DERIVED VIEW SOURCE: ACCESS-CONTROL.md + WORKFLOWS.md

Ma trận Phân quyền và Kích hoạt Hành động

Authorization route-level không đủ. Mỗi command phải đồng thời thỏa role, resource scope, domain state và business preconditions tại server.

> **ACTION ELIGIBILITY = ROLE ∧ RESOURCE SCOPE ∧ DOMAIN STATE ∧ BUSINESS PRECONDITIONS**

Hành động	Staff	Manager	Admin	Guard chính
StartTask	ALLOW	DENY	DENY	`assignedStaffId = actorId` và `PEND`
ReportFieldIssue	ALLOW	DENY	DENY	Đúng người được giao; chỉ từ `IN_PROGR`
SubmitEvidence	ALLOW	DENY	DENY	Proof policy, site verification, expectedVe
ResubmitRework	ALLOW	DENY	DENY	Chỉ từ `REWORK_REQUIRED`; giữ lịch sử bằ
CreateTask	DENY	ALLOW	DENY	Tree và assignee nằm trong authorized s
ReviewTask	DENY	ALLOW	DENY	`WAITING_REVIEW`; decision-specific field
ReassignTask	DENY	ALLOW	DENY	Chỉ `PENDING/BLOCKED`; cấm direct reass
Platform governance	DENY	DENY	ALLOW	Account/policy/config scope; không trao

Review decisions: `APPROVE`, `APPROVE_WITH_EXCEPTION`, `REQUEST_REWORK`, `CANCEL`. Mỗi nhánh có trường bắt buộc riêng.

Hard deny: account disabled, token stale/revoked, resource ngoài hoặc Admin cố thao tác nghiệp vụ hiện trường.

Server API là authorization boundary tối cao · client visibility không phải quyền thực thi.